

Exercises

1	2	3	4	5	6	7
---	---	---	---	---	---	---

Surname, First name

Abbas Al-Zubi, Zubair

Network Security Exam (CS4430)

Endterm

5	3	4	2	0	0	7
1	1	1	1	1	1	1
2	2	2	X	2	2	2
3	X	3	3	3	3	3
4	4	X	4	4	4	4
X	5	5	5	5	5	5
6	6	6	6	6	6	6
7	7	7	7	7	7	X
8	8	8	8	8	8	8
9	9	9	9	9	9	9
0	0	0	0	X	X	0

a	X	c	d	e	f	→ b
●	b	c	X	e	f	→ a
X	b	X	d	e	f	→ c
X	b	X	●	e	f	→ d

Answer multiple-choice questions as shown in the example.

Welcome to the CS4330 - Network Security exam on June 19, 2025.

Please fill out your student number in the box on the right upper side of this page, and fill the corresponding boxes.

Important information

- You have 3 hours to complete the exam.
- You are allowed to use the slides, which you can also bring on a laptop / tablet. When using a laptop, the use of the keyboard is **not allowed**. The keyboard should be covered. You may not use any other tools or materials.
- Throughout the exam there are boxes you can use to fill in your answers. Any answer written outside of these boxes will not be considered.
- If you run out of space on a question, there is extra space at the end of the exam. Please state clearly in the question that you will be using the extra space, or it will not be considered. Note that we expect the answers to fit in the provided space.
- The exam has 25 points in total.

Good luck

Harm, George, and the TAs!

Link Layer

- 2p 1a (1) What is ARP spoofing?
(2) What kind of attack does it enable and how?

ARP maps IP address to MAC address in LAN. In ARP spoofing the attacker impersonates a host and sends spoofed ARP messages to a victim, thus poisoning their cache. The victim then sends their packets to the attacker, It enables cache poisoning attack: victims update their ARP cache with malicious entries.

- 2p 1b Explain how **double tagging** works and why this can allow an attacker to send traffic from one VLAN into another. Motivate your answer using a simple example.

In some switches, only one level of decapsulation is performed. This allows the attacker to embed an inner second tag, this^{is} known as double-tagging. The switch will decapsulate first tag and forward the traffic to the next switch, ~~however~~ It will then assume that it's legitimate traffic, even though it isn't.

Network Layer - IP spoofing

- 1p 2a You send a spoofed IP packet to a server, claiming to be from a trusted client. The server replies to the spoofed IP address. Why don't you receive the reply?

This is due to amplification attacks in the DNS, where the reply is sent to the victim with spoofed IP.

- 2p 2b What techniques can an attacker use to overcome this? Name one for a Local network, and one for the Internet.

For local network: ingress filtering

For the ~~web~~ internet: by using routing (indirect delivery)

Network Layer - ICMP

- 1p 3a Describe how a file can be exfiltrated using ICMP echo request packets.

A file can be exfiltrated as follows: if the TTL is too ~~big~~ long in the ICMP echo request, the packets can be intercepted and sniffed in the mean time.

2p **3b** Why might this traffic evade some firewalls or intrusion detection systems?

The traffic might not get captured by the firewall or IDS due to lack of specific pre-defined rules or ~~signatures~~ ~~that~~ ~~capture~~ that match this traffic, or due to lack of flagged IP addresses in the traffic.

Transport Layer

1p **4a** Why are SYN Cookies successful in mitigating SYN-flood attacks?

SYN cookies provide TCP authentication. Instead of allocating resources immediately upon receiving a SYN, the server encodes connection information into the initial sequence number (the SYN cookie) using a crypto hash. This approach prevents resource exhaustion, as the server does not store half-open connections in the backlog queue until the handshake is validated.

2p **4b** You suspect a TCP RST attack is taking place in your network. How would you investigate a network capture to verify this?

This can be done by using a tool like Wireshark to monitor the network and the activity that is taking place. From which the important info can be extracted, such as source/destination IP/port, data length, sequence number etc.

- 3p 4c You are attempting a TCP hijack between a client and server. You've sniffed a few packets. Explain step-by-step how to inject a valid packet into the session.

First, the spoofed TCP packet is made. Then, the attacker sends the victim a message indicating that ~~it's~~ it's coming from a trusted host. The attacker gets the session information by conducting ARP spoofing and MITM attack, thus allowing the attacker to inject ~~per~~ valid packets into the session and ~~to~~ attacking the victim.

Application Layer

- 1p 5a In a DNS hijack attack, how would you make sure that your spoofed DNS response is accepted by the victim instead of the legitimate one?

This can be accomplished by replying back with a response faster than the DNS server, while spoofing the IP address of the DNS server. The client then connects to the IP address provided by the attacker.

- 1p 5b What changes or configurations on a DNS resolver can **prevent** a cache poisoning attack from working? Explain your answer.

By applying DNSSEC, which adds authentication and integrity to DNS responses. It adds cryptographic signatures to DNS responses, which enables clients to verify the authenticity and integrity

- 3p 5c (1) Describe how TLS interception works at a high level.
(2) How can an attacker use a custom certificate authority (CA) in this attack?

TLS interception is performed by software on middleboxes/transport proxies located in between the client and HTTPS website or on the client's machine. Thus the middleboxes or proxies act as MITM. They terminate the encrypted session, decrypt traffic and then re-establish a secure connection with the client. This requires clients to trust and install a root certificate^(CA) on their device.

Cyber Threat Intelligence

3p 6a Consider the following SNORT rule:

```
alert ip $EXTERNAL_NET any -> $HOME_NET any ( msg:"Network Security Exam Question";  
content:"AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA";)
```

- (1) What does this rule detect, and what attack could that be associated with?
- (2) Explain how you would circumvent this detection as an attacker.

It detects malicious messages from external to Home network, with the content "AAAAA....". It also alerts at IP level, and the rule applies to any source and destination address.

An attacker could circumvent ~~this~~ this by encrypting the message so that the ciphertext is undetectable.

This attack could be associated with TCP session hijacking.

1p 6b In terms of the Cyber Kill Chain, what phase might this rule relate to? Justify your answer.

It relates to the delivery phase, as it detects ^{and where} how the malicious payload is delivered.

Extra Space

7 Space

- ①b Example: An attacker embeds two VLAN tags:
- The first is stripped by the first switch.
 - The second VLAN tag is then used to forward the frame into a different VLAN.
- This attack can bypass VLAN boundaries, and/or conduct DoS attack.